

ENCRYPTION POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Encryption Policy
Document ID	POL-ENC-001
Current Version	1.0
Approved Date	August 18, 2026
Approved By	Information Security Steering Committee
Effective Date	August 18, 2026
Next Review Date	August 18, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 18, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 18, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criterion CC6.7, and GDPR Article 32. The settings that deliver it are in the Cloud Platform Standard.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE5

2 SCOPE5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY5

5 REQUIREMENTS6

6 ALGORITHMS AND CHANGE.....6

7 RECORDS.....7

8 EXCEPTIONS7

9 REFERENCE.....7

10 DOCUMENT POLICY HISTORY.....7

1 Overview and Purpose

This Policy states what PromptHalo Technologies (“the Company”) requires of encryption. It is short because the requirements are met by platform defaults rather than by anything the Company builds.

2 Scope

This Policy covers Company and client information in transit and at rest in the AWS estate, Google Workspace and GitHub, and the secrets that protect it.

3 Roles and Definitions

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **At rest** — information stored on disk, in a database, in object storage, or in a backup or snapshot.
3. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
4. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
6. **In transit** — information moving over a network, including between the Company's own services.
7. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
8. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
9. **Secret** — a credential, key or token that protects access to information or a system.

10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
12. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Requirements

1. Information in transit is encrypted with TLS 1.2 as a minimum and 1.3 preferred, restricted to forward-secret authenticated cipher suites, with plain HTTP redirected. [SOC 2: CC6.7 · GDPR Art. 32]
2. Confidential and Restricted information is encrypted at rest with AES-256 or equivalent. Cloud storage, databases, backups and snapshots have encryption enabled by default at account level, so a resource created without thought is still encrypted. [SOC 2: CC6.7]
3. Secrets are held in a managed secrets service or the password manager and retrieved at runtime. They do not appear in source, in environment files committed to the repository, in tickets, in chat or in logs. [SOC 2: CC6.7]
4. Keys are managed by the platform's key service, with rotation enabled where the service supports it. The Company does not operate its own key infrastructure. [SOC 2: CC6.7]
5. Where the Company holds the keys, deletion may be affected by destroying them, and that destruction is recorded — which is the practical route to proving deletion in an all-cloud estate. [SOC 2: CC6.5, CC6.7]
6. Certificates are issued and renewed automatically by the platform's certificate service. Where a certificate cannot be automated, its expiry date is recorded in the asset inventory, and an alert is set ahead of it. An expired certificate is an outage the Company caused itself, and it is the commonest avoidable one. [SOC 2: CC6.7, CC7.2]

6 Algorithms and Change

1. The Company uses algorithms and key lengths that current national guidance considers sound and does not implement its own cryptography. Where a platform offers a stronger default, it is taken. [SOC 2: CC6.7]
2. Where a protocol or algorithm the Company relies on is deprecated or broken, that is a significant change: it is recorded, assessed under the Risk Management Policy, and remediated on a timescale set by exposure rather than convenience. [SOC 2: CC3.4, CC6.7]
3. Legacy cryptography retained because a client or a platform requires it is recorded as an exception with a compensating measure and a review date, rather than left as an undocumented weaker path. [SOC 2: CC5.3, CC6.7]
4. The Company does not run its own post-quantum migration. It relies on its platform providers to adopt post-quantum algorithms and tracks their announcements through the external

information source list. That is the proportionate position at this size, and stating it is better than silence. [SOC 2: CC3.4, CC6.7]

7 Records

1. Account-level encryption settings evidencing defaults. [SOC 2: CC6.7]
2. Transport configuration evaluated continuously against the baseline. [SOC 2: CC6.7, CC7.1]
3. Key destruction records were used to evidence deletion. [SOC 2: CC6.5]

8 Exceptions

Where a service cannot meet these requirements, the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

9 Reference

1. SOC 2 Trust Services Criteria, Security category [CC6.5, CC6.7, CC7.1]
2. STD-CLD-001 Cloud Platform Standard [SOC 2: CC6.7]
3. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
4. POL-DCL-001 Data Classification Policy [SOC 2: CC2.1]
5. POL-PWD-001 Password and Authentication Policy [SOC 2: CC6.1]
6. EU General Data Protection Regulation, Article 32

10 Document Policy History

Version	Date	Description
1.0	August 18, 2026	Initial policy release